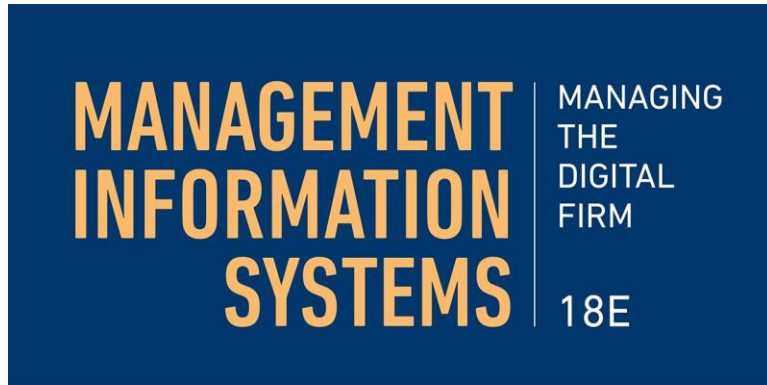


Management Information Systems: Managing the Digital Firm

Eighteenth Edition



Chapter 8

Securing Information Systems



KENNETH C. LAUDON | JANE P. LAUDON | CAROL G. TRAVER

Learning Objectives

- 8.1 Understand why information systems are vulnerable.
- 8.2 Describe the most prevalent and dangerous types of malware.
- 8.3 Understand the dangers posed by threat actors.
- 8.4 Describe the security issues raised by software vulnerabilities.
- 8.5 Describe the security issues raised by artificial intelligence.
- 8.6 Describe the business value of security and control.
- 8.7 Describe an organizational framework for security and control.
- 8.8 Discuss technologies for safeguarding information resources.
- 8.9 Understand how the information in this chapter can help your career.

Why Information Systems Are Vulnerable

(1 of 3)

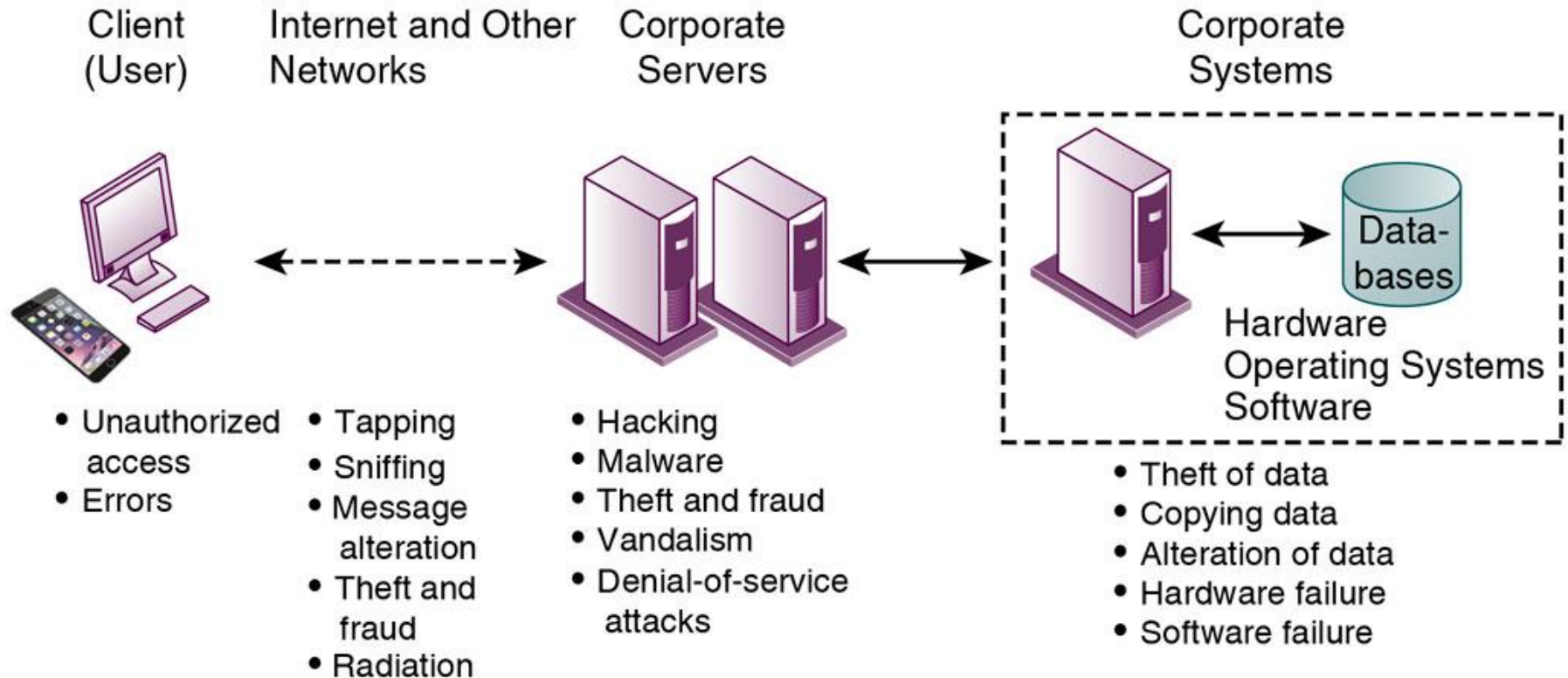
- If you operate a business today, you need to make security and control top priorities
 - Security
 - Policies, procedures, and technical measures used to prevent unauthorized access, alteration, theft, or physical damage to information systems
 - Controls
 - Methods, policies, and organizational procedures that ensure safety of organization's assets; accuracy and reliability of its accounting records; and operational adherence to management standards

Why Information Systems Are Vulnerable

(2 of 3)

- Threats can stem from technical, organizational, and environmental factors and be compounded by poor management decisions
 - Threat actor
 - An individual or group of individuals seeking to exploit system vulnerabilities to intentionally cause harm
 - System malfunctions
 - Domestic or offshore partnering can lead to vulnerability
 - Portability
 - Vulnerability

Figure 8.1 Contemporary Security Challenges and Vulnerabilities



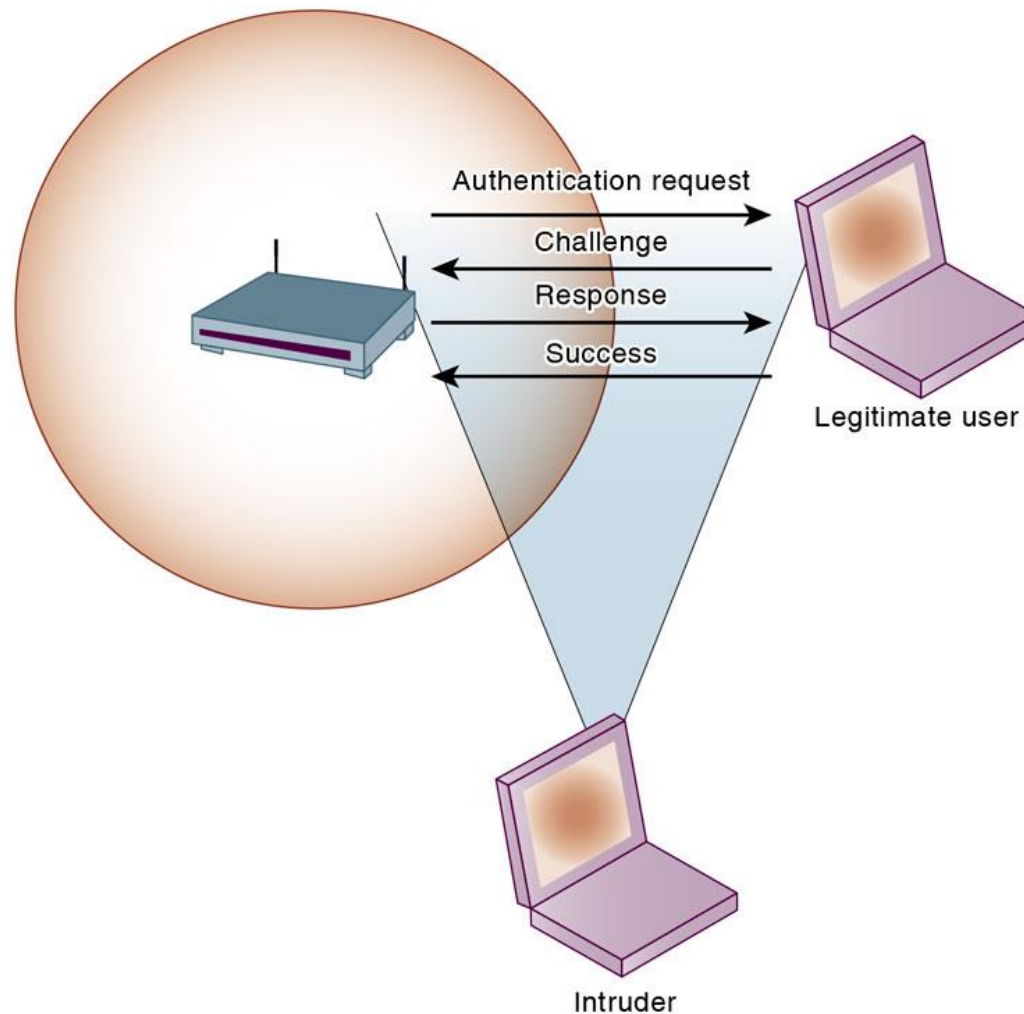
Copyright © 2026 by Pearson Education, Inc.

Why Information Systems Are Vulnerable

(3 of 3)

- Sniffer
 - A type of eavesdropping program that monitors information traveling over a network
- Both Bluetooth and Wi-Fi networks are susceptible to hacking by eavesdroppers
 - Wardriving
 - Eavesdroppers drive by buildings or park and try to intercept wireless network traffic
 - Rogue access points
 - Intruders also use the information they have gleaned to set up rogue access points (RAP) on a different radio channel in physical locations near users to force a user's radio network interface controller (NIC) to associate with the RAP.

Figure 8.2 Wi-Fi Security Challenges



Copyright © 2026 by Pearson Education, Inc.

The Most Prevalent and Dangerous Types of Malware (1 of 6)

- Malware (malicious software programs)
 - Variety of threats
 - Viruses, Worms, Trojan horses, Ransomware, Bot
 - Potentially unwanted programs (PUPs)
 - Include adware, browser parasites, spyware, and other applications such as rogue security software, toolbars, and PC diagnostic tools that install themselves onto a user's computer.

The Most Prevalent and Dangerous Types of Malware (2 of 6)

- Drive-by download
 - malware that a user unintentionally downloads or that is downloaded without the user's knowledge
- Malvertising
 - to embed malware in the online advertising chain, including via Google and other ad networks
- Keylogger
 - a form of spyware that records every keystroke made on a computer to steal serial numbers for software
 - e.g., Zeus Trojan uses Keylogging

The Most Prevalent and Dangerous Types of Malware (3 of 6)

- Viruses

- a rogue software program that attaches itself to other software programs or data files to be executed, usually without user knowledge or permission.
 - Viruses typically spread from computer to computer when humans take an action, such as sending an email attachment or copying an infected file.

- Worms

- a software program that independently copies itself from one computer to another computer over a network, and which can destroy data & programs, as well as disrupt or even halt the operation of a computer network.
 - Unlike viruses, worms can operate on their own without attaching to other computer program files and rely less on human behavior to spread rapidly from computer to computer.

The Most Prevalent and Dangerous Types of Malware (4 of 6)

- Trojan horses

- a software program that appears to be legitimate but which contains hidden functionality that may cause damage.
 - not a virus since it does not replicate, but it is often a way for viruses or other malicious code to be introduced into a computer system.
 - e.g., Zeus (Zbot) Trojan, which has infected millions computers worldwide over the years and still poses a threat.
 - It has been used to steal login credentials for banking by surreptitiously capturing people's keystrokes as they use their computers.
 - Zeus is spread mainly through drive-by downloads and phishing, and recent variants have been difficult to eradicate.

The Most Prevalent and Dangerous Types of Malware (5 of 6)

- Ransomware

- malware that tries to extort money from users by taking control of their computers and blocking access to files.
 - one of the most significant cyberthreats currently facing business, with the number of known attacks increasing by almost 70 percent in 2023, and the average ransom demand progressively climbing.
 - increasingly deployed in the form of **ransomware-as-a-service**, a cybercrime business model.
 - developers of ransomware sell or rent the ransomware code to other groups, known as affiliates, in return for an upfront payment and/or share of the proceeds of an attack (Malwarebytes, 2024).

The Most Prevalent and Dangerous Types of Malware (6 of 6)

- Bot
 - type of malicious code that can be covertly installed on a computer when it is attached to the Internet, and which, once installed, responds to external commands sent by an attacker.
 - Computers infected with bot malware may become part of a botnet, which is a collection of captured computers that can then be used for malicious purposes;
 - E.g., distributed denial of service (DDoS) attacks, phishing campaigns, or spam, without their owners' knowledge.

Table 8.1 Notable Examples of Malware

Name	Type	Description
Emotet	Trojan/Botnet	Described by Europol as the world's most dangerous malware. Initially used to steal bank login credentials by surreptitiously capturing people's keystrokes. Later versions added malware delivery services, including other Trojans and ransomware, and were spread via botnet. In January 2021, an internationally coordinated effort took down many Emotet botnets, but by November 2021, it had once again resurfaced, indicating how difficult it is to fully eradicate. Still active as of 2024.
Cryptolocker	Ransomware/ Trojan	Hijacks users' data such as photos, videos, and text documents; encrypts them with virtually unbreakable asymmetric encryption; and demands ransom payment for them.
Conficker	Worm	First detected in November 2008 and still a problem for users of older, unpatched Windows operating systems. Uses flaws in Windows software to take over machines and link them into a virtual computer that can be commanded remotely. Had nearly 10 million computers worldwide under its control. Difficult to eradicate.
Sasser.ftp	Worm	First appeared in 2004. Spread over the Internet by attacking random IP addresses. Caused computers to continually crash and reboot and infected computers to search for more victims. Affected millions of computers worldwide and caused an estimated \$14.8 billion to \$18.6 billion in damages.
ILOVEYOU	Virus	First detected on May 3, 2000. Script virus written in Visual Basic script and transmitted as an email attachment with the subject line ILOVEYOU. Overwrote music, image, and other files with a copy of itself and did an estimated \$10 billion to \$15 billion in damage.

Mobile Devices and Security Threats

- More than 80% of organizations faced some attack aimed primarily at users' mobile devices in 2023 according to Verizon, while Kaspersky reported a more than 50% increase in attacks targeting mobile devices, with the number surging to more than 33 million.
 - Android, is the mobile platform targeted by most threat actors.
 - E.g., Malwarebytes detected Android banking trojans, disguised as regular apps like QR code scanners, fitness trackers, and even copies of popular apps like Instagram, more than 88,000 times in 2023.
 - Apple devices are also at risk.
 - E.g., in February 2024, a new sophisticated mobile trojan specifically aimed at iOS users was found to be collecting facial recognition data, identity documents, and intercepting SMS.
 - Mobile device malware poses serious threats to enterprise computing because so many wireless devices are now linked to corporate information systems (Verizon, 2023; Kaspersky, 2024; Malwarebytes, 2024).

Other Technology Related Threats

- Social networks such as Facebook, X (formerly Twitter), and LinkedIn have emerged as conduits for malware.
 - E.g., Facebook Messenger virus is spread by phishing messages sent from a hijacked Facebook account to people in the victim's Facebook contact list.
 - The virus's ability to replicate contributes to its widespread and persistent nature (Danes, 2023).
- Malware is also starting to be targeted at the 3D virtual reality environment known as the metaverse.
 - The hardware needed for virtual reality and augmented reality platforms has created new endpoints to exploit. Attackers can potentially manipulate platforms to create physical dangers.
 - The privacy of participants and the security of their personal information are also a concern (Rosenblatt, 2023).

Dangers Posted by Threat Actors (1 of 3)

- There are numerous types of threat actors
 - Cybercriminals
 - Hackers
 - Ethical hackers work under an agreement with the target firms that they will not be prosecuted for their efforts to break in.
 - E.g., Apple, Microsoft, Intel, HP, and many others are willing to pay monetary bounties to hackers who discover bugs in their software and hardware.
 - Hacktivists – are motivated to attack specific targets based on ideology
 - Often engage in cybervandalism - the intentional disruption, defacement, or even destruction of a website or corporate information system.
- Threat actors often employ "**spoofing**"
 - The practice of tricking or deceiving others by hiding one's true identity

Dangers Posted by Threat Actors (2 of 3)

- One popular form of spoofing is

- **Phishing**

- Involves setting up fake websites or sending email messages that look like those of legitimate businesses to ask users for confidential personal data
 - Phishing often involves
 - Social engineering
 - exploits human curiosity, greed, gullibility, fear, or complacency to trick people
 - Evil twin
 - a wireless network that pretends to offer a trustworthy Wi-Fi connection to the Internet, e.g., at airport lounges, hotels, coffe-shops
 - Pharming
 - redirects users to a bogus web page even when the users type the correct web page address into their browser ~ the ISP servers should be careful about.

Dangers Posted by Threat Actors (3 of 3)

- Advanced persistent attacks
 - **Living off the Land attack (LOTL attack)**
 - Often referred to as a “fileless” attack; hijacks legitimate software tools, such as network administration tools like Windows Mgt Interface
 - **Advanced persistent threat attack (APT attack)**
 - Prolonged attack where an intruder infiltrates the system and remains undetected for an extended period of time
 - **Denial-of-service attack (DoS attack)**
 - Attackers flood a network or web server with thousands of false communications or service requests in order to crash the network
 - **Distributed denial-of-service attack (DDoS attack)**
 - Often employs a botnet to inundate and overwhelm a network,
 - e.g., the Mirai botnet overwhelmed the Dyn servers, taking down Etsy, GitHub, Netflix, Shopify, SoundCloud, Spotify, Twitter, and a number of other major websites.

Data Breaches and Identity Theft

- Data breach
 - the loss of control over an organization's data
- Credential stuffing attack
 - a brute force attack that attackers launch via botnets and automated tools using known username and password combinations obtained from data breaches
 - becoming increasingly common, especially in the financial services.
- Identity theft
 - a crime in which an imposter obtains key pieces of personal information, such as social security numbers, driver's license numbers, or credit card numbers, to impersonate someone else.

Global Threats

- Cyberwarfare
 - State-sponsored politically motivated activity designed to harm another state or nation
 - Although many potential targets are military, a country's power grids, dams, financial systems, communications networks, and voting systems can also be crippled.
 - Non-state actors such as terrorists or criminal groups can mount attacks, and it is often difficult to identify who is responsible.
- Cyberterrorism
 - Executed by a terrorist group

Internal Threats: Employees

- Security threats often originate inside an organization
- Inside knowledge
- Sloppy security procedures
 - Users' lack of knowledge is the single-greatest cause of network security breaches
- Social engineering
 - malicious intruders often use social engineering techniques to obtain system access, e.g., tricking employees into revealing passwords
- Both end users and information systems specialists are sources of risk

Computer Crime (1 of 2)

- Computer crime defined by U.S. Department of Justice as any violations of criminal law that involve a knowledge of computer technology for their perpetration, investigation, or prosecution.
- Computer may be target of crime
- Computer may be instrument of crime

Table 8.3 Examples of Computer Crime

Computers As Targets of Crime

Breaching the confidentiality of protected data
Accessing a computer system without authority to do so
Knowingly accessing a protected computer to commit fraud
Intentionally accessing a protected computer and causing damage negligently or deliberately
Knowingly transmitting a program, program code, or command that intentionally causes damage to a protected computer
Threatening to cause damage to a protected computer

Computers As Instruments of Crime

Stealing trade secrets
Unauthorized copying of software or copyrighted intellectual property, such as articles, books, music, and video
Scheming to defraud
Using email or messaging for threats or harassment
Intentionally attempting to intercept electronic communication
Illegally accessing stored electronic communications, including email and voice mail
Transmitting or possessing child pornography by using a computer



Computer Crime (2 of 2)

There are numerous state and federal laws to try to prevent or reduce computer crime.

No one knows the magnitude of computer crime—how many systems are invaded, how many people engage in the practice, or the total economic damage that results from computer crime.

The estimated global cost of cybercrime in 2024 will be \$9.5 trillion.

Security Issues Raised by Software Vulnerabilities (1 of 2)

- Commercial software contains flaws that create security vulnerabilities
 - Bugs (program code defects)
 - Zero defects cannot be achieved
 - Flaws can open networks to intruders
- Zero-day vulnerability
 - a vulnerability in software unknown to its creator, especially troublesome -- the author of the software has zero days after learning about it to patch the code before it can be exploited in an attack.
 - E.g., Log4Shell, in an open-source Java logging tool, Apache Log4j, allowed attackers to take control of susceptible servers.

Security Issues Raised by Software Vulnerabilities (2 of 2)

- **SQL injection attack**

- exploits vulnerabilities in poorly coded web application software to introduce malicious program code into a company's systems and networks.
 - Occurs when a web application fails to validate properly or filter user data on a web page, which might occur when ordering something online. An attacker uses this input validation error to send a rogue SQL query to the underlying database to access the data, plant malicious code, or access other systems on the network.
 - E.g., The popular secure file transfer service MOVEit, used by thousands of organizations, was hacked in 2023 when the Clop ransomware group was able to exploit a zero-day SQL injection vulnerability that allowed threat actors to gain unauthorized access to customer environments.

- **Patches and patch management**

- Software to repair the flaws without disturbing the proper operation of the software

- **Software supply chain attack**

- a threat actor infiltrating the software supply chain at the development and production stage and compromising the software before it is acquired and deployed by the customer -- may occur in either newly acquired software, as part of an update, or even as part of a patch.

Security Issues Raised by Artificial Intelligence

- Phishing with AI
 - GenAI tools such as WormGPT and others are increasingly being used to help cybercriminals create unique and extremely realistic phishing emails.
- Deepfakes
 - use of AI to create highly realistic, but digitally fabricated or fake, images or audio
 - can be used to impersonate the voice and image of a real person, and the fake content can show people doing and saying things they never actually did; can be used for fraud, blackmail, and the spread of misinformation and propaganda.
- Subverting LLMs
 - **prompt injection attack or jailbreaking**
 - involves using specialized prompts designed to manipulate the LLM to produce inappropriate content, disclose sensitive information, or execute harmful code.
 - Security researchers believe that most LLMs are susceptible to such attacks.

Business Value of Security and Control

(1 of 3)

- Failed computer systems can lead to significant or total loss of business function
 - It is believed that 40% of all businesses will not recover from application or data losses that are not repaired within three days.
- A security breach may cut into a firm's market value almost immediately
 - E.g., Target, a mass merchandise retailer, had to pay more than \$150 million to settle various legal claims filed by banks, credit card companies, and consumers against Target related to a massive hack of Target's payment systems.
- Inadequate security and control may result in serious legal liability
 - Developing a sound security and control framework that protects business information assets is of critical importance to the entire enterprise, including senior management. It can no longer be limited to the IT department.

Business Value of Security and Control

(2 of 3)

- Electronic records management (ERM)
- Health Insurance Portability and Accountability Act (HIPAA)
- Gramm-Leach-Bliley Act (or Financial Services Modernization Act)
 - Requires financial institutions to ensure the security & confidentiality of customer data
- Sarbanes-Oxley Act (or Public Company Accounting Reform and Investor Protection Act)
 - Imposes responsibility on companies and their management to safeguard the accuracy and integrity of financial information that is used internally and released externally
- Firms must also be aware of, and comply with, data storage and retention requirements imposed by various privacy laws and regulations, e.g., the **European Union's General Data Protection Regulation (GDPR)**.

Business Value of Security and Control

(3 of 3)

- Electronic evidence (**electronically stored information - ESI**)
 - Evidence for white collar crimes often in digital form
 - Proper control of data can save time and money when responding to legal discovery request
- **Digital forensics**
 - Scientific collection, examination, authentication, preservation, and analysis of data from computer storage media for use as evidence in court of law
 - Recovery of ambient data
- An awareness of digital forensics should be incorporated into a firm's contingency planning process.
 - E.g., CIO, security specialists, information systems staff, and corporate legal counsel should work together to have a plan in place that can be executed if a legal need arises.

Organizational Framework for Security and Control

- Need to develop a security policy
 - May be automated or manual
- General controls
 - Govern design, security, and use of computer programs and security of data files in general throughout organization
- Application controls
 - Controls unique to each computerized application
 - Input controls, processing controls, output controls

Risk Assessment

- Determines level of risk to firm if specific activity or process is not properly controlled
 - Types of threat
 - Probability of occurrence during year
 - Potential losses, value of threat
 - Expected annual loss

Risk assessment determines the level of risk to a firm if a specific activity or process is not properly controlled.

Table 8.5 Online Order Processing Risk Assessment

Exposure	Probability of Occurrence (%)	Loss Range/Average (\$)	Expected Annual Loss (\$)
Power failure	30%	\$5,000–\$200,000 (\$102,500)	\$30,750
Embezzlement	5%	\$1,000–\$50,000 (\$25,500)	\$1,275
User error	98%	\$200–\$40,000 (\$20,100)	\$19,698

Copyright © 2026 by Pearson Education, Inc.

Security Policy

- Security policy
 - Consists of statements ranking information risks, identifying acceptable security goals, and identifying the mechanisms for achieving these goals
 - Drives other policies
- Acceptable use policy (AUP)
 - Defines acceptable uses of firm's information resources and computing equipment

Disaster Recovery Planning and Business Continuity Planning

- Disaster recovery planning
 - Devises plans for restoration of disrupted services
- Business continuity planning
 - Focuses on restoring business operations after disaster
- Both types of plans needed to identify firm's most critical systems
 - Business impact analysis to determine impact of an outage
 - Management must determine which systems restored first

The Role of Auditing

- Information systems audit
 - Examines firm's overall security environment as well as controls governing individual information systems
- Security audits
 - Review technologies, procedures, documentation, training, and personnel
- List and rank control weaknesses and the probability of occurrence
- Assess financial and organizational impact of each threat

Technologies for Safeguarding Information Resources (1 of 4)

- Identity and access management software (IAM software)
 - Automates keeping track of all users and privileges
- Zero trust
 - Popular cybersecurity framework based on the principle of maintaining strict access controls

Technologies for Safeguarding Information Resources (2 of 4)

- Authentication

- The ability to know that people are who they claim to be

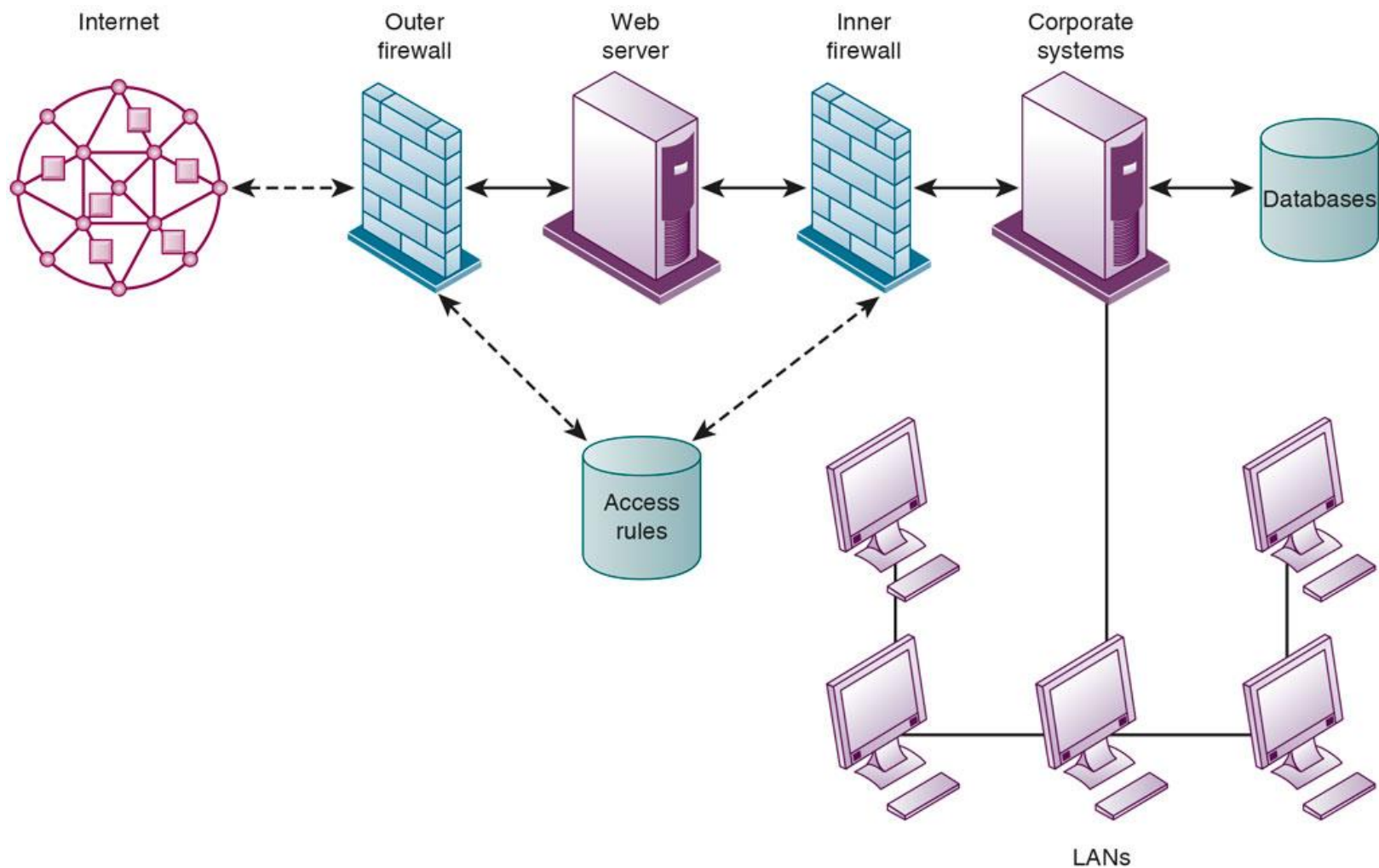
- Password
 - Token
 - Smart cards
 - Biometric authentication
 - Multifactor authentication
 - Two-factor authentication

Technologies for Safeguarding Information Resources (3 of 4)

- Firewall

- Prevents unauthorized users from accessing private networks
- Packet filtering
- Stateful inspection
- Network address translation (NAT)
- Application gateways
- Next-generation firewall (NGFW)

Figure 8.5 A Corporate Firewall



Copyright © 2026 by Pearson Education, Inc.

Technologies for Safeguarding Information Resources (4 of 4)

- Intrusion detection system
 - Monitors hot spots on corporate networks to detect and deter intruders
- Intrusion prevention system (IPS)
 - Additional ability to take steps to prevent and block suspicious activities
- Anti-malware software
 - Detects and eliminates malware
- Unified threat management (UTM) systems
 - Combines various security tools

Securing Wireless Networks

- WEP
- WPA2
- WPA3

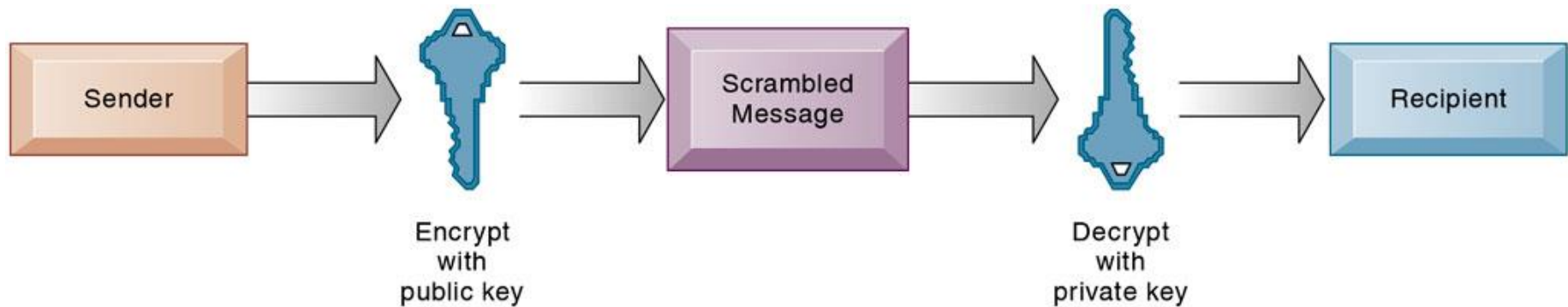
Encryption and Public Key Infrastructure

(1 of 2)

- Encryption

- Process of transforming plain text or data into cipher text read only the sender and intended receiver
- Transport Layer Security (TLS)
- HTTPS
- Public key encryption

Figure 8.6 Public Key Encryption



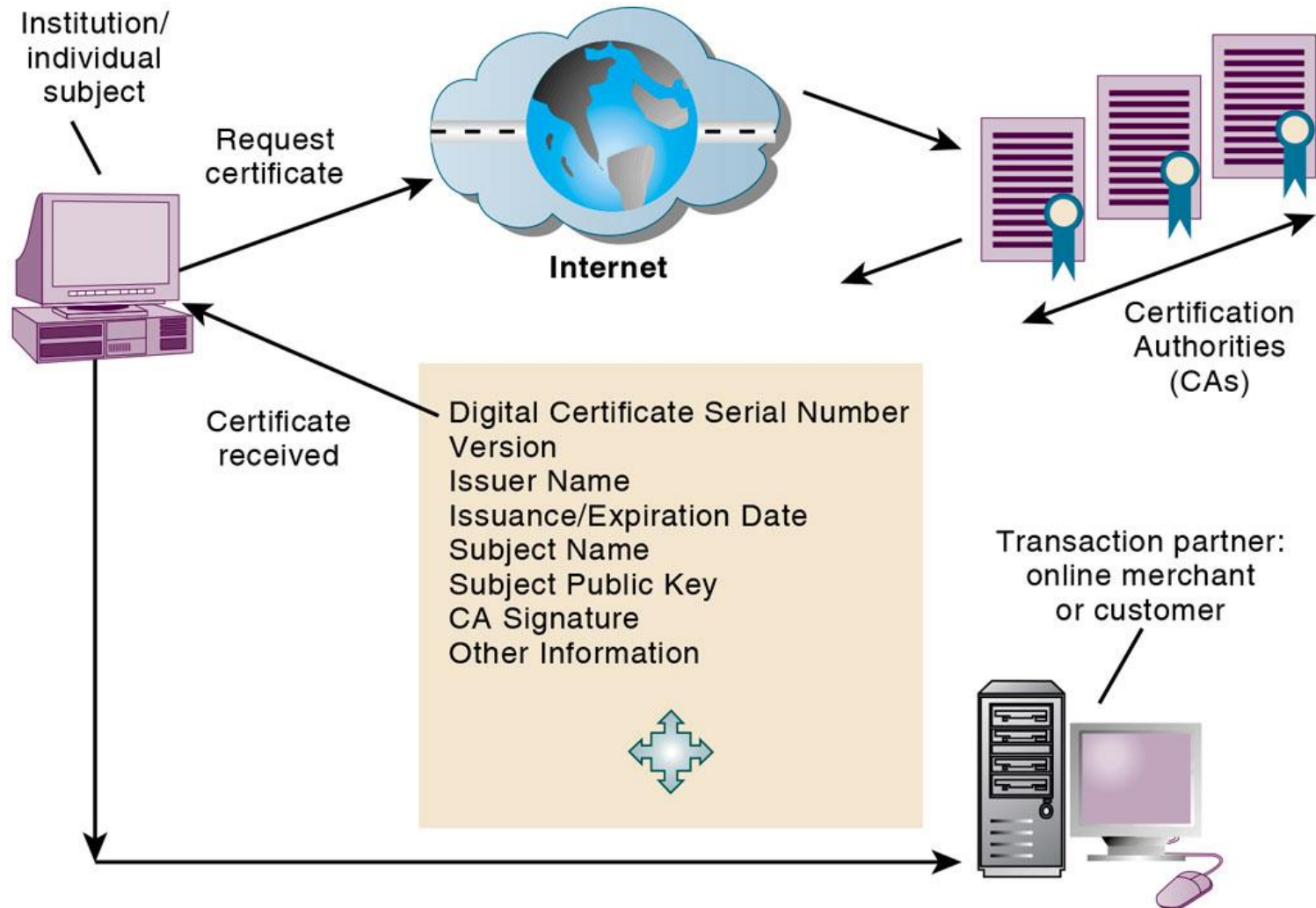
Copyright © 2026 by Pearson Education, Inc.

Encryption and Public Key Infrastructure

(2 of 2)

- Digital certificate
 - Data file used to establish the identity of users and electronic assets for protection of online transactions
- Public key infrastructure (PKI)
 - Use of public key cryptography working with certificate authority
 - Widely used in e-commerce

Figure 8.7 Digital Certificates



Copyright © 2026 by Pearson Education, Inc.

Securing Transactions with Blockchain

- A blockchain is a chain of digital “blocks” that contain records of transactions
 - Secure transaction database
 - Encryption used to verify users and transactions
 - Decentralized
 - Records cannot be changed
 - Blockchain has some vulnerabilities requiring attention to security and controls
 - Cryptocurrencies

Ensuring System Availability

- Online transaction processing requires 100% availability
- Fault-tolerant computer systems
 - Contain redundant hardware, software, and power supply components that create an environment that provides continuous, uninterrupted service
- Security operations center
- Managed security service providers (MSSPs)
- Digital resiliency

Security Issues for Cloud Computing and the Mobile Digital Platform (1 of 2)

- Security in the cloud
 - Responsibility for security resides with company owning the data
 - Firms must ensure providers provide adequate protection:
 - Where data are stored
 - Meeting corporate requirements, legal privacy laws
 - Segregation of data from other clients
 - Audits and security certifications
 - Service level agreements (SLAs)

Security Issues for Cloud Computing and the Mobile Digital Platform (2 of 2)

- Securing mobile platforms
 - Security policies should include and cover any special requirements for mobile devices
 - Guidelines for use of platforms and applications
 - Mobile device management (MDM)
 - Authorization
 - Inventory records
 - Control updates
 - Lock down/erase lost devices
 - Encryption
 - Software for segregating corporate data on devices

Ensuring Software Quality

- Software metrics: Objective assessments of system in form of quantified measurements
 - Number of transactions
 - Online response time
 - Payroll checks printed per hour
 - Known bugs per hundred lines of code
- Early and regular testing
- Walkthrough: Review of specification or design document by small group of qualified people
- Debugging: Process by which errors are eliminated

Copyright



This work is protected by United States copyright laws and is provided solely for the use of instructors in teaching their courses and assessing student learning. Dissemination or sale of any part of this work (including on the World Wide Web) will destroy the integrity of the work and is not permitted. The work and materials from it should never be made available to students except by instructors using the accompanying text in their classes. All recipients of this work are expected to abide by these restrictions and to honor the intended pedagogical purposes and the needs of other instructors who rely on these materials.